

INTE2669 Assignment 1

Part A

Q1:

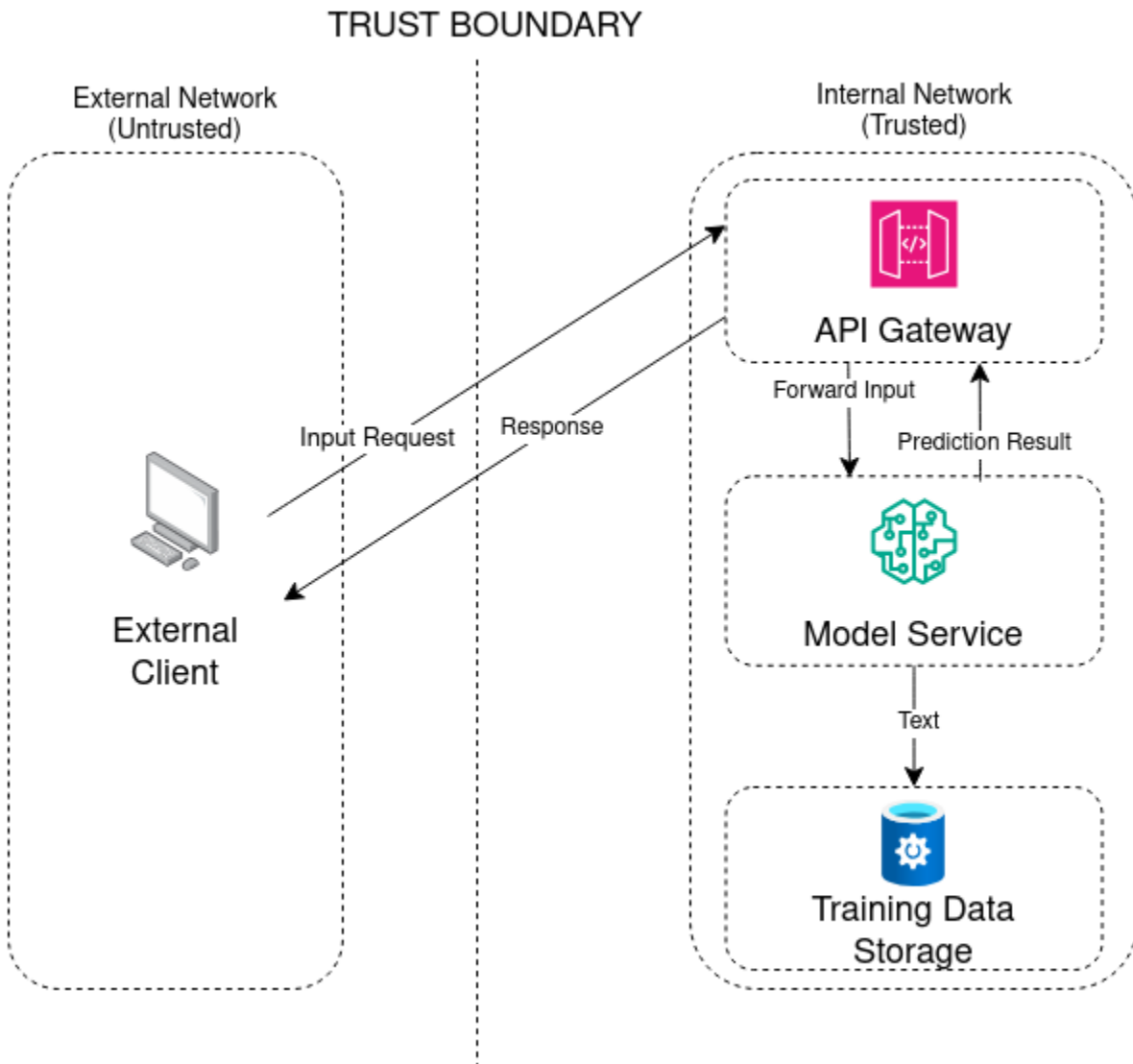


Figure 1: System Architecture

- Figure 01 shows the architecture of the hiring-screen AI API system and its trust boundaries. The external client application operates outside the system's trust boundary and communicates with the API gateway by submitting applicant data. The API forwards requests to the internal model service, which generates prediction outputs based on the trained machine learning model. The model is trained using

applicant data stored in the training data storage, which is in the trusted environment. The primary attack surface exists at the API interface, where an external user can repeatedly query the system and observe prediction outputs. This exposure creates a risk of model extraction through systematic querying.

Q2:

Data Asset	Attacker	Access & Capabilities	Potential Harm
Trained ML Model	Competitor organization	Can repeatedly query the API with crafted inputs and observe prediction scores or labels	Model can be replicated (model stealing), resulting in loss of intellectual property and competitive advantage
Prediction Outputs	Malicious API user	Has legitimate API access and can send large volumes of queries to collect input-output pairs	Enables reconstruction of decision boundaries, facilitating model extraction and reducing the value of the deployed system
Training Dataset	Curious or malicious client	Indirect access via model outputs and inference techniques	Potential leakage of sensitive applicant information, leading to privacy violations and legal/regulatory consequences

Table 1: Asset-Attacker-Harm

Q3:

- I selected the model stealing track because the system architecture in Figure 1 exposes prediction outputs through an API interface to external clients across a trust boundary. This creates a direct attack surface where an untrusted user can repeatedly query the model and observe its outputs.
- As identified in Table 1, the trained model is a critical asset, and prediction outputs provide useful information that can be collected by an attacker. With sufficient queries, a malicious user can approximate the model's decision behaviour and reconstruct a surrogate model. Therefore, model stealing represents a realistic and high-impact threat in this scenario compared to other attack types.

Part B

Q4:

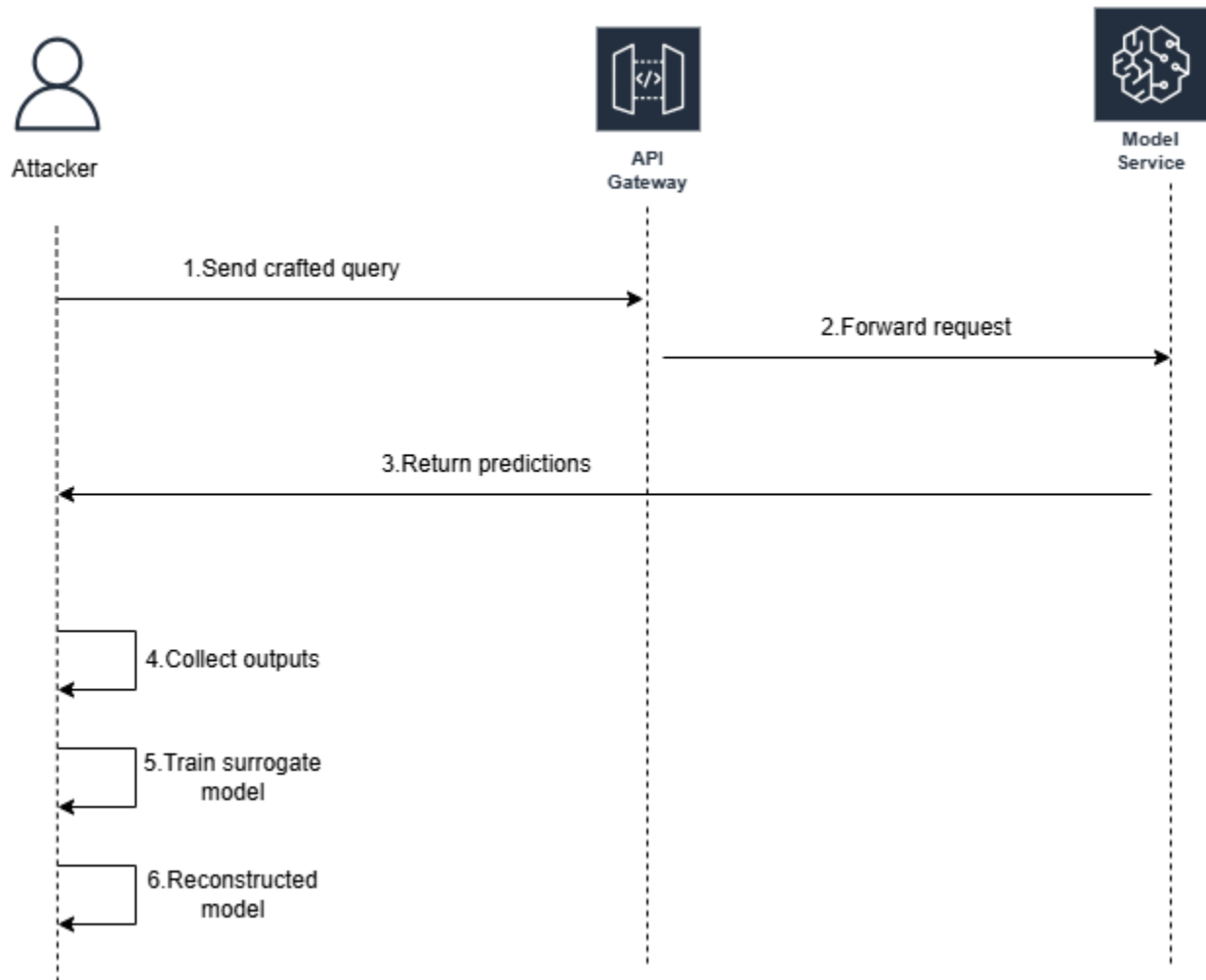


Figure 2: Attack / Abuse Workflow

The attack workflow begins when an external attacker interacts with the API by sending a large number of carefully crafted input queries. These inputs are designed to explore different regions of the model's decision space.

The API forwards these requests to the internal model, which returns prediction outputs such as confidence scores or labels. The attacker collects these input-output pairs and uses them to train a surrogate model that mimics the behaviour of the original model. A successful outcome is achieved when the attacker can approximate the decision boundary or prediction behaviour of the target model with high accuracy, effectively replicating its functionality.

Q5:

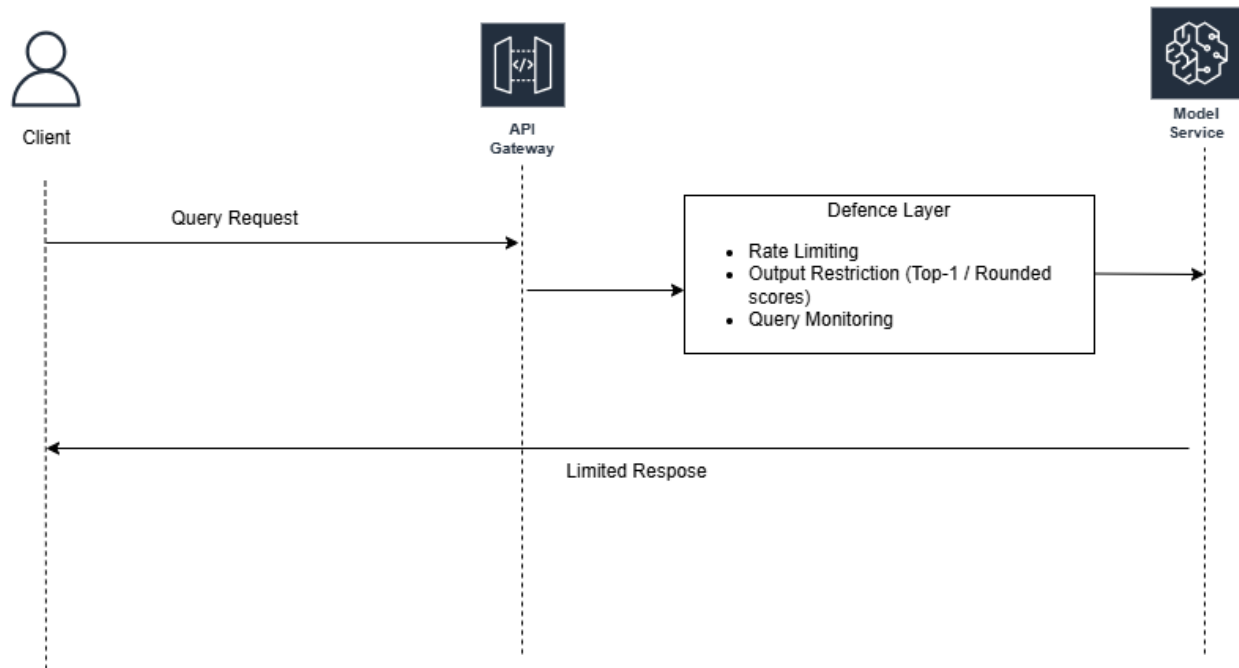


Figure 3: Defense Workflow

1. Rationale for combining defenses

The proposed defense workflow integrates multiple protection mechanisms to effectively mitigate model stealing attacks. Rate limiting restricts the number of queries that a client can issue within a given time period, thereby preventing large scale data collection. Output restriction reduces the level of detail in model responses, such as by returning only top-1 labels or rounded confidence values. In addition, query monitoring is used to identify abnormal access patterns that may indicate automated or malicious behaviour. The combination of these mechanisms provides a layered defense approach.

2. Reduction of vulnerability

The effectiveness of the attack described in Q4 depends on the attacker's ability to gather a large volume of high quality input-output pairs. The proposed defences reduce both the quantity and quality of information available to the attacker. Rate limiting reduces the number of queries that can be performed, while output restriction limits the precision of the returned predictions. For instance, providing only top-1 labels removes confidence information, and rounding prediction scores reduces their usefulness. As a result, the attacker is unable to accurately approximate the model's decision boundary, significantly weakening the attack.

3. Trade-offs

While the proposed defenses improve security, they introduce several trade-offs. Rate limiting may negatively affect usability by restricting legitimate users who require frequent access to the service. Output restriction can reduce utility, as less detailed predictions may not meet the needs of client applications. Furthermore, implementing query monitoring and detection mechanisms increases system complexity and operational cost. Therefore, a balance must be achieved between security, usability, and performance.

Part C

Q6:

```
Substitute epoch 1/2 | loss: 1.6835
Substitute epoch 2/2 | loss: 0.8422
Substitute epoch 1/2 | loss: 1.6697
Substitute epoch 2/2 | loss: 0.8236
Substitute epoch 1/2 | loss: 1.6585
Substitute epoch 2/2 | loss: 0.6917

Baseline
track: model_stealing
api_mode: full
target_eval_acc: 0.7620
substitute_eval_acc: 0.6420
agreement_with_target: 0.7980
mean_abs_output_difference: 0.0408
query_budget: 1500

Rounded confidence defence
track: model_stealing
api_mode: rounded
target_eval_acc: 0.7620
substitute_eval_acc: 0.6380
agreement_with_target: 0.7810
mean_abs_output_difference: 0.0457
query_budget: 1500

Top-1 label defence
track: model_stealing
api_mode: top1
target_eval_acc: 0.7620
substitute_eval_acc: 0.6460
agreement_with_target: 0.7690
mean_abs_output_difference: 0.0692
query_budget: 1500
```

Figure 4: `model_stealing_track.py` output

- The required lines were completed to implement rounded confidence outputs, top-1 label outputs, and substitute model predictions.

Q7:

Output Setting	Information Available to Attacker	Agreement with Target	Mean Output Difference	Attack Effectiveness
Full response scores	Full probability distribution across all classes	0.798	0.0408	High
Rounded confidence values	Approximate probabilities (reduced precision)	0.781	0.0457	Medium
Top-1 labels only	Only predicted class label (no confidence information)	0.769	0.0692	Low

Table 2: Comparison of Model Stealing Effectiveness Across Different Output Settings

- The above Table 2 compares the effectiveness of the model stealing attack under three different output settings. In the baseline case full response scores are available. The attacker has access to complete probability distributions. This provides detailed information about the model's decision boundaries and confidence levels, resulting in the highest agreement (0.798) and lowest output difference (0.0408), indicating a highly successful attack.
- Rounding the confidence values lowers the output precision. Although attacker still receives useful information, some additional details are lost. This leads to a slight decrease in agreement (0.781) and an increase in output difference (0.0457), showing that the attack becomes less accurate but remains effective.
- In the top-1 label setting, only the predicted class is returned without any confidence information. This limits the attacker's ability to understand the model's behaviour. As a result the agreement further decreases (0.769) and the output difference increases (0.0692), indicating the weakest attack among the three settings.

Q8:

Attacker Goal	Full Outputs	Rounded Confidence	Top-1 Labels
Reproduce final predictions	Very effective	Effective	Still effective
Approximate decision boundary	Highly effective	Moderately effective	Limited effectiveness
Imitate confidence behaviour	Fully possible	Partially possible	Not possible

Table 3: Impact of Output Restrictions on Different Attacker Goals

- The result of the model stealing attack depends on the attacker's objective. Table 3 shows how different output restrictions affect attacker goals.
- If the attacker's goal is to reproduce the final prediction of the model, even top-1 label outputs are often sufficient. This is because the attacker only needs to learn which class is selected for a given input, rather than the underlying confidence distribution. This is reflective in the relatively high agreement observed even in the top-1 setting (0.769).
- However, if the attacker aims to approximate the decision boundary of the model, more detailed information is required. Full probability outputs provide rich information about how close inputs are to classification boundaries, making this task highly effective. Rounded confidence values reduce precision but still preserve general trends, allowing partial boundary approximation. In contrast, top-1 labels remove this information entirely, making it significantly harder to infer boundary regions.
- For attackers attempting to imitate the confidence behaviour of the model, full outputs are essential. Rounded outputs only provide approximate confidence levels, limiting accuracy, while top-1 labels do not provide any confidence information at all. As a result, this goal becomes infeasible under the top-1 defence.

Q9:

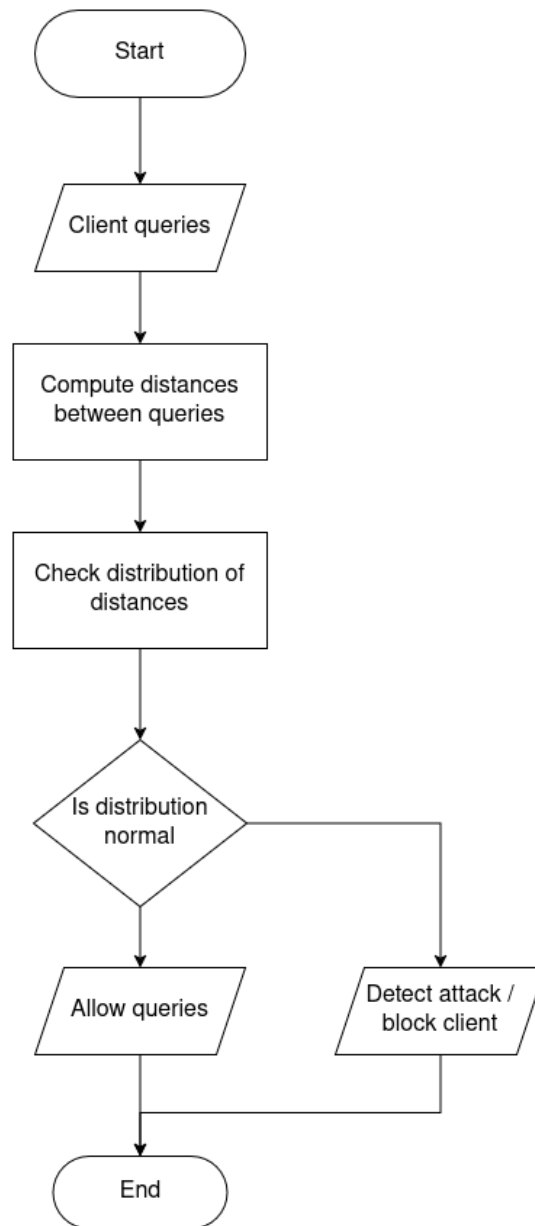


Figure 4: PRADA-Based Model Stealing Detection Workflow

- PRADA (Protecting Against DNN Model Stealing Attacks) is a defence mechanism that detects model extraction attacks by analysing patterns in a sequence of queries made by a client. Instead of evaluating individual queries, PRADA monitors how multiple queries relate to each other over time.
- The main idea is that benign users submit natural inputs that follow a consistent distribution, while attackers generate carefully crafted queries to explore the model's decision space. As a result, the distances between attacker-generated

queries deviate from a normal distribution. PRADA computes the distances between successive queries and analyses their distribution using statistical tests. If the distribution significantly deviates from a normal pattern, the system flags the activity as a potential model stealing attack.

- This defence changes what the attacker can do by limiting their ability to issue large numbers of structured queries without being detected. Since model stealing attacks rely on systematically probing the model with carefully selected inputs, detecting abnormal query patterns reduces the amount of useful data the attacker can collect.
- As a result, PRADA reduces the effectiveness of model stealing attacks by identifying and stopping suspicious query behaviour, even when individual queries appear legitimate.

Part D

Q10:

- Deployment Recommendation: Approve with Conditions
- The system should not be deployed in its current form without additional safeguards, as the results from the model stealing experiment demonstrate that an attacker can approximate the model's behaviour with relatively high agreement (up to 0.798 in the baseline case). This indicates a clear risk of model extraction through repeated API queries.
- However, the proposed defence mechanisms, including output restriction, rate limiting, and query pattern monitoring (PRADA), significantly reduce the effectiveness of the attack by limiting both the quantity and quality of information available to an attacker.
- Therefore, the system can be approved for deployment only if these defences are properly implemented and enforced. Continuous monitoring and periodic evaluation are also recommended to ensure that new attack strategies do not bypass existing protections.